

— Footprinting & Reconnaissance (Module 02) — CEH v13

Module 02 Kya Cover Karti Hai?

Footprinting = Target ke baare mein **maximum information collect karna** before launching any attack.

2 Types of Footprinting:

Type	Description	Examples
Passive	Target ko directly touch nahi karte — third-party sources se info	Google, Social media, WHOIS, Job sites
Active	Target system ko directly interact karte hain	DNS queries, Ping sweeps, Port scans

— PASSIVE FOOTPRINTING

Google Hacking / Google Dorking

Google ke advanced search operators se sensitive information find karna.

◆ Google Dorks

bash

Specific site search

site:example.com

File type search

site:example.com filetype:pdf

site:example.com filetype:xls

site:example.com filetype:doc

site:example.com filetype:sql

site:example.com filetype:log

site:example.com filetype:bak

Specific page search

intitle:"index of" site:example.com

inurl:admin site:example.com

inurl:login site:example.com

inurl:wp-admin site:example.com

Sensitive information

site:example.com "password"

site:example.com "confidential"

site:example.com "username"

site:example.com "api_key"

site:example.com "SECRET_KEY"

site:example.com "BEGIN RSA PRIVATE KEY"

site:example.com "email" "@example.com"

Cameras & Devices

intitle:"webcam" inurl:"viewer"

intitle:"Live View / - AXIS"

intitle:"Network Camera"

Exposed Files

intitle:"index of" "backup"

intitle:"index of" "database"

intitle:"index of" "server-status"

SQL/DB errors

site:example.com "SQL Syntax" "MySQL"

site:example.com "Warning: mysql_connect()"

◆ **Google Dorking Automation (Kali Tools)**

bash

Goog-Dork

git clone https://github.com/Z4nzu/hackingtool.git *# Alternative tool*

Pagodo (automated Google dorking)

git clone https://github.com/opsdisk/pagodo.git

cd pagodo

python3 pagodo.py -d example.com -g dorks.txt

🔍WHOIS Lookup

Domain registration details find karo — registrar, owner, emails, nameservers, expiry date.

bash

Kali terminal se

whois example.com

Output example:

Domain Name: EXAMPLE.COM

Registrar: GODADDY.COM

Registrant Name: John Doe

Registrant Organization: Example Corp

Registrant Email: john@example.com

Name Server: NS1.EXAMPLE.COM

Creation Date: 2000-01-01

Expiry Date: 2027-01-01

◆ Key Info WHOIS

Field	Importance
Registrant Name	Target organization/individual
Registrant Email	Phishing/social engineering ke liye
Name Servers	DNS servers — further enum ke liye
Registrar	Hosting provider
Expiry Date	Domain renewal — hijacking possibility

3 DNS Reconnaissance

bash

nslookup — Basic DNS queries

nslookup example.com # A record (IP address)

nslookup -type=MX example.com # Mail servers

nslookup -type=NS example.com # Name servers

nslookup -type=TXT example.com # TXT records (SPF, DKIM)

nslookup -type=SOA example.com # Start of Authority

nslookup -type=ANY example.com # All records (old method)

dig — Advanced DNS queries

dig example.com # A record

dig example.com MX # Mail servers

dig example.com NS # Name servers

dig example.com TXT # TXT records

dig example.com SOA # SOA record

dig example.com CNAME # CNAME records

dig example.com AAAA # IPv6 address

dig -x 192.168.1.10 *# Reverse DNS lookup (IP → Hostname)*

Zone transfer (agar vulnerable ho)

dig axfr @ns1.example.com example.com

🔗 OSINT (Open Source Intelligence) — Kali Tools

◆ theHarvester (Email, Subdomain, IP collection)

bash

Basic usage

theHarvester -d example.com -b google

Multiple sources

theHarvester -d example.com -b google,bing,yahoo,linkedin

theHarvester -d example.com -b all

Save output

theHarvester -d example.com -b all -f output.html

DNS brute force

theHarvester -d example.com -b dns

◆ Recon-ng (Full OSINT Framework)

bash

Start Recon-ng

recon-ng

Marketplace se modules dekhna

marketplace search

Module install karna

marketplace install recon/domains-hosts/bing_domain_web

marketplace install recon/contacts-contacts/mailtester

Workspace banao

workspaces create example_recon

workspaces list

Module load karo

modules load recon/domains-hosts/bing_domain_web

Domain set karo

options set SOURCE example.com

Run karo

run

Results dekhna

show hosts

show contacts

show domains

Report generate karo

modules load reporting/list

options set FILENAME /root/example_recon.html

run

◆ **Maltego (GUI-based OSINT Tool)**

bash

Kali mein Maltego install

apt install maltego

Open → Run as root nahi karna

Register (free account)

New Graph → Palette se entities drag karo:

→ Domain → right-click → "To DNS Name"

→ Person → right-click → "To Email Address"

→ Company → right-click → "To Website"

◆ **Shodan (Internet-connected devices search)**

bash

Browser: <https://www.shodan.io>

Search Queries:

port:21 country:IN — FTP servers in India

webcam city:"New Delhi" — Cameras in Delhi

org:"Indian Army" — Army IP ranges (agar indexed ho)

vuln:CVE-2024-23897 — Vulnerable devices filter

CLI se bhi use kar sakte (API key chahiye)

shodan search --limit 10 "apache country:IN"

◆ **Censys (Similar to Shodan)**

bash

<https://search.censys.io/>

Certificates, hosts aur services search

5 Email Footprinting

◆ **Email Tracking**

bash

```
# Email headers analyse karo
# Gmail mein: Open email → More → Show original
# Headers se milte hain:
# Return-Path — Origin server
# Received: from — IP path
# X-Originating-IP — Original sender IP
# SPF/DKIM/DMARC — Authentication status
```

```
# theHarvester se emails bhi milte hain
theHarvester -d example.com -b google,linkedin
```

◆ Email OSINT Tools

```
bash
# Verify email existence
# Hunter.io: https://hunter.io
# EmailHippo: https://emailhippo.com
# HaveIBeenPwned: https://haveibeenpwned.com (data breach check)
```

```
# Email tracer
python3 -c "
import smtplib
# VRFY command se email check
# (Telnet se)
# telnet mail.example.com 25
# VRFY john@example.com
"
```

6 Social Media Footprinting

```
bash
```


LinkedIn — Employees, positions, technologies, skills

Facebook/Twitter — Personal info, habits, relationships

Instagram — Location-based info

Glassdoor — Internal work culture, salary info

Automated tools (use carefully)

Social-Engineer Toolkit (SET) — profile cloning

LinkedInt — LinkedIn scraping

Twint — Twitter OSINT

Twint (Twitter scraping)

git clone <https://github.com/twintproject/twint.git>

cd twint

pip3 install -r requirements.txt

python3 -m twint -u username -o output.txt

But Twint is mostly deprecated now — burp ya browser-based collection better

Website Footprinting

◆ WhatWeb (Web technology detection)

bash

Website ki technology stack identify karo

whatweb example.com

Aggressive mode

whatweb -a 3 example.com

Multiple targets

whatweb example.com example.org

Output save

`whatweb example.com --log-verbose=whatweb_output.txt`

◆ **BuiltWith (Online Tool)**

`bash`

Browser: <https://builtwith.com/example.com>

Shows: CMS, frameworks, analytics, hosting, CDN, SSL

◆ **Wappalyzer (Browser Extension)**

`bash`

Firefox/Chrome mein extension install karo

Visit any website → Extension icon → Tech stack dikhata hai

🔗 Job Sites & Resume OSINT

`bash`

Naukri.com, LinkedIn, Indeed — Job postings se pata chalega:

- Technologies use kar rahe hain (firewalls, SIEM, etc.)

- Network architecture info

- Employee names & email patterns

- IT infrastructure details

Google dork for resumes

`site:linkedin.com "SAP" "Indian Army"`

`site:naukri.com "cybersecurity" "defence"`

`site:resume.example.com filetype:pdf`

— ACTIVE FOOTPRINTING

📄 Website Mirroring (Offline Copy)

`bash`

HTTrack — Website ka full offline copy banao

```
httrack https://example.com -o /root/website_copy/
```

Wget se bhi kar sakte

```
wget -m -p -k https://example.com
```

-m: mirror, -p: download all assets, -k: convert links for offline

2 DNS Zone Transfer (Active)

```
bash
```

Manual zone transfer attempt

```
dig axfr @ns1.example.com example.com
```

If success → full DNS records milte hain

Hostage: "Transfer failed" — vulnerable nahi hai

3 Email Tracking (Read Receipts)

```
bash
```

MailTracking.app

Pixel tracking: Ek transparent 1x1 image bhejo

Jab target email kholta hai → pixel load hota hai → server pe log

Demo: Python script

```
python3 -c "
```

```
import smtplib
```

```
from email.mime.text import MIMEText
```

```
from email.mime.multipart import MIMEMultipart
```

```
msg = MIMEMultipart()
```

```
msg['From'] = 'attacker@evil.com'
msg['To'] = 'target@example.com'
msg['Subject'] = 'Important Document'
```

```
# Hidden tracking pixel
```

```
html = '<html><body><img src=\"http://attacker-server.com/track?id=123\" width=\"0\" height=\"0\"></body></html>'
```

```
msg.attach(MIMEText(html, 'html'))
```

```
# Send — requires SMTP server
```

```
print('Email ready for sending')
```

```
"
```

4. Subdomain Enumeration (Active)

◆ Sublist3r

```
bash
```

```
# Subdomain find karo
```

```
sublist3r -d example.com
```

```
# Verbose mode
```

```
sublist3r -v -d example.com
```

```
# Port scan bhi karo
```

```
sublist3r -d example.com -p 80,443
```

```
# Output file
```

```
sublist3r -d example.com -o subdomains.txt
```

◆ DNS Bruteforce

```
bash
```

```
# dnsrecon
```

```
dnsrecon -d example.com -D /usr/share/seclists/Discovery/DNS/subdomains-  
top1million-5000.txt -t brt
```

```
# dnsenum
```

```
dnsenum example.com
```

```
# Gobuster DNS mode
```

```
gobuster dns -d example.com -w /usr/share/seclists/Discovery/DNS/subdomains-  
top1million-5000.txt -t 50
```

```
# Massdns
```

```
massdns -r /usr/share/seclists/Resolvers/resolvers.txt -t A -w output.txt domains.txt
```

5 Network Footprinting (Active)

```
bash
```

```
# Ping sweep to find live hosts
```

```
for i in $(seq 1 254); do ping -c 1 -W 1 192.168.1.$i | grep "64 bytes" | cut -d" " -f4 | tr -d  
"; done
```

```
# Nmap ping sweep
```

```
nmap -sn 192.168.1.0/24
```

```
# TTL analysis (OS detection)
```

```
ping 192.168.1.20
```

```
# TTL=64 → Linux
```

```
# TTL=128 → Windows
```

```
# TTL=255 → Cisco/Network device
```

Traceroute

tracert 8.8.8.8

tracert -n example.com

6 Social Engineering Footprinting

◆ **SET (Social Engineering Toolkit) — Credential Harvesting**

bash

SET start

setoolkit

Menu:

1) Social-Engineering Attacks

2) Website Attack Vectors

3) Credential Harvester Attack Method

4) Site Cloner

Enter target URL (e.g., https://www.facebook.com)

Enter local IP (your Kali IP)

Target ko link bhejo → jab kholta hai → credentials capture

◆ **Phishing Email Creation Demo**

bash

SET me:

1) Social-Engineering Attacks

2) Spear-Phishing Attack Vectors

3) Create a FileFormat Payload

Ya Mail templates bhi use kar sakte

7 Eavesdropping (Sniffing for Info)

```
bash
```

```
# Wireshark — Passive sniffing
```

```
wireshark
```

```
# tcpdump — CLI sniffing
```

```
tcpdump -i eth0 -n
```

```
tcpdump -i eth0 port 53      # DNS traffic
```

```
tcpdump -i eth0 port 80      # HTTP traffic
```

```
tcpdump -i eth0 host 192.168.1.20 # Specific host
```

```
tcpdump -i eth0 -w capture.pcap # Save to file
```

```
tcpdump -r capture.pcap      # Read saved file
```

Complete Footprinting Lab —Script

```
bash
```

```
#!/bin/bash
```

```
# Save as: footprinting.sh
```

```
# chmod +x footprinting.sh
```

```
# ./footprinting.sh example.com
```

```
DOMAIN=$1
```

```
TARGET_IP=$2
```

```
OUTPUT_DIR="footprinting_$DOMAIN"
```

```
mkdir -p $OUTPUT_DIR/{whois,dns,google,osint,subdomains,network}
```

```
echo "====="
```

```
echo " COMPLETE FOOTPRINTING ON: $DOMAIN"
```

```
echo "====="
```

[1] WHOIS

echo "[1] WHOIS Lookup..."

whois \$DOMAIN > \$OUTPUT_DIR/whois/whois.txt 2>/dev/null

[2] DNS Records

echo "[2] DNS Records..."

dig \$DOMAIN > \$OUTPUT_DIR/dns/dns_a_record.txt

dig \$DOMAIN MX > \$OUTPUT_DIR/dns/dns_mx.txt

dig \$DOMAIN NS > \$OUTPUT_DIR/dns/dns_ns.txt

dig \$DOMAIN TXT > \$OUTPUT_DIR/dns/dns_txt.txt

dig \$DOMAIN SOA > \$OUTPUT_DIR/dns/dns_soa.txt

[3] Zone Transfer Attempt

echo "[3] Zone Transfer Attempt..."

for ns in \$(dig NS \$DOMAIN +short); do

 echo "Trying: \$ns"

 dig axfr @\$ns \$DOMAIN >> \$OUTPUT_DIR/dns/zone_transfer.txt 2>/dev/null

done

[4] Web Technology

echo "[4] Web Technology Fingerprinting..."

whatweb \$DOMAIN > \$OUTPUT_DIR/whatweb.txt 2>/dev/null

[5] Subdomain Enumeration

echo "[5] Subdomain Enumeration..."

sublist3r -d \$DOMAIN -o \$OUTPUT_DIR/subdomains/sublist3r.txt 2>/dev/null


```
dnsrecon -d $DOMAIN -t brt -D /usr/share/seclists/Discovery/DNS/subdomains-  
top1million-20000.txt > $OUTPUT_DIR/subdomains/dnsrecon.txt 2>/dev/null
```

[6] Email Harvesting

```
echo "[6] Email Harvesting..."
```

```
theHarvester -d $DOMAIN -b google > $OUTPUT_DIR/osint/theharvester_google.txt  
2>/dev/null
```

```
theHarvester -d $DOMAIN -b bing >> $OUTPUT_DIR/osint/theharvester_bing.txt  
2>/dev/null
```

[7] Google Dorking Notes

```
echo "[7] Google Dork Queries (Manual)..."
```

```
cat > $OUTPUT_DIR/google/dorks.txt << EOF
```

```
Google Dorks for $DOMAIN
```

```
=====
```

```
site:$DOMAIN filetype:pdf
```

```
site:$DOMAIN filetype:xls
```

```
site:$DOMAIN filetype:sql
```

```
site:$DOMAIN inurl:admin
```

```
site:$DOMAIN intitle:"index of"
```

```
site:$DOMAIN "password"
```

```
site:$DOMAIN "confidential"
```

```
site:$DOMAIN "api_key"
```

```
EOF
```

[8] Network (if IP provided)

```
if [ ! -z "$TARGET_IP" ]; then
```

```
    echo "[8] Network Scan..."
```

```
    nmap -sn $TARGET_IP/24 > $OUTPUT_DIR/network/ping_sweep.txt 2>/dev/null
```

```
tracert -n $TARGET_IP > $OUTPUT_DIR/network/tracert.txt 2>/dev/null

fi

echo ""

echo "===== "

echo " OUTPUT SAVED IN: $OUTPUT_DIR/"

echo "===== "

echo ""

echo "=== QUICK SUMMARY ==="

echo "WHOIS:"

head -20 $OUTPUT_DIR/whois/whois.txt 2>/dev/null

echo ""

echo "Name Servers:"

dig NS $DOMAIN +short 2>/dev/null

echo ""

echo "Mail Servers:"

dig MX $DOMAIN +short 2>/dev/null

echo ""

echo "Web Server:"

head -10 $OUTPUT_DIR/whatweb.txt 2>/dev/null

echo ""

echo "Subdomains Found:"

cat $OUTPUT_DIR/subdomains/sublist3r.txt 2>/dev/null

echo ""

echo "Emails Found:"

grep -o '[a-zA-Z0-9._%+-]\+@[a-zA-Z0-9.-]\+\.[a-zA-Z]{2,\}' $OUTPUT_DIR/osint/*.txt 2>/dev/null
```

Footprinting Output Template

Har footprinting session ke baad ye table fill karein:

Category	Info Found	Source/Tool
Domain		
IP Address		
Name Servers		
Mail Servers		
Registrar		
Registrant		
Tech Stack		WhatWeb
Subdomains		Sublist3r
Email Addresses		theHarvester
Employees Names		LinkedIn/Google
Technologies Used		BuiltWith
Physical Address		WHOIS
Phone Numbers		WHOIS/Google
Social Media		Manual search
Job Postings		LinkedIn/Naukri
Hidden Files/Dirs		Google Dorking

Module 02 — Complete Tools Reference

Tool	Category	Command
whois	Info Gathering	whois example.com
dig	DNS Enum	dig example.com MX
nslookup	DNS Query	nslookup -type=MX example.com
dnsrecon	DNS Enum	dnsrecon -d example.com -t brt
dnsenum	DNS Enum	dnsenum example.com

Tool	Category	Command
sublist3r	Subdomain	sublist3r -d example.com
theHarvester	OSINT	theHarvester -d example.com -b all
Recon-ng	OSINT Framework	recon-ng
Maltego	OSINT GUI	maltego
WhatWeb	Web Tech	whatweb example.com
HTTrack	Website Mirror	httrack example.com -o /tmp/
Google Dorks	Manual	Browser search operators
Shodan	Device Search	Browser/API
Censys	Certificate Search	Browser
SET	Social Eng	setoolkit
Wireshark	Sniffing	wireshark
tcpdump	CLI Sniffing	tcpdump -i eth0

Defence Side Note — Footprinting se Bachav

Technique	Defence Mechanism
WHOIS exposure	Private WHOIS / Domain privacy enable karein
Google Dorking	Sensitive files ko robots.txt se block karein
Subdomain discovery	Wildcard DNS records, unnecessary subdomains hatao
Directory listing	Web server se directory listing disable karo
Email harvesting	Public pages par emails mat daalo, contact forms use karo
Social media OSINT	OPSEC training — employees ko social media policy do
Job posting leaks	Job ads mein internal tech stack details mat daalo
DNS zone transfer	Zone transfer sirf authorized NS ko allow karo
Web tech fingerprinting	Server headers customize karo, WAF use karo
Shodan exposure	Internet-facing ports ko minimize karo